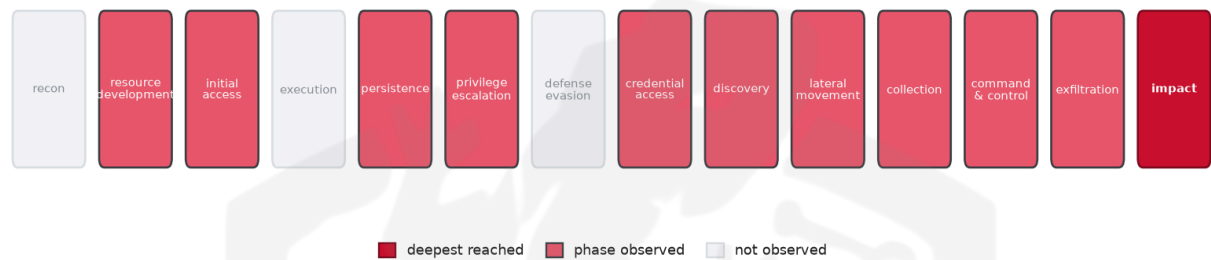


THREAT REPORT: UNKNOWN_ADVERSARY CAMPAIGN

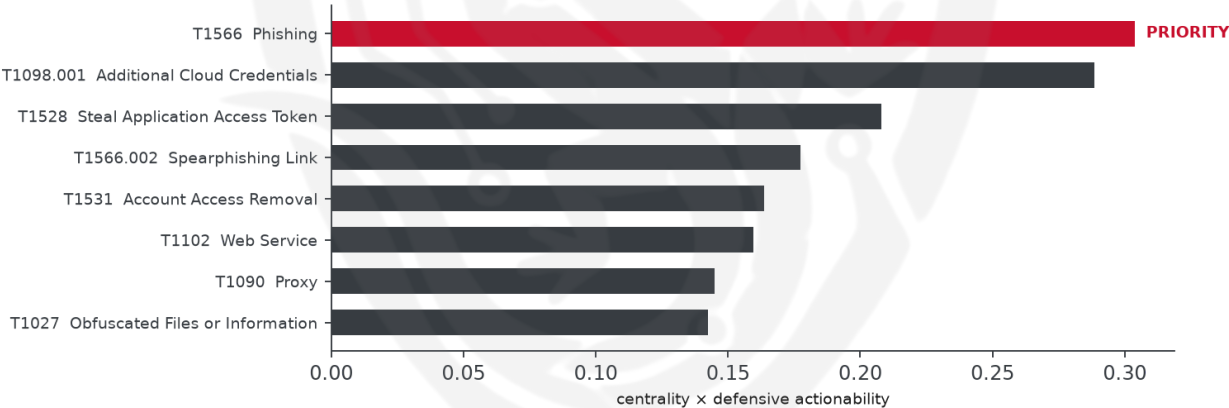
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: impact)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The observed cluster of activity has been targeting the finance and healthcare sectors, utilizing malware families such as ARToken and EvilTokens. The threat actor's identity and targeted country remain unknown. Priority should be given to defensive actions that mitigate phishing attacks, as this technique has been identified as a critical chokepoint in the attack chain. Enable attachment sandboxing and link rewriting to prevent initial compromise.

Threat Overview

The threat actor, whose identity is unknown, has been observed using various techniques to steal web session cookies, application access tokens, and cloud credentials. The malware families ARToken and

EvilTokens have been identified as part of this campaign. The threat actor's targets include organizations in the finance and healthcare sectors, although the specific countries targeted are unknown.

Attack Chain and Priority Control

The attack chain involves a range of techniques, including phishing, spearphishing, and stealing web session cookies. The priority technique is T1566 Phishing, which serves as a critical chokepoint in the attack chain. To mitigate this threat, the priority control is to: Enable attachment sandboxing and link rewriting; block macro-enabled Office docs from the internet zone; deploy a user report-phish button.

Infrastructure and Corroboration

There is no available information on the hosting providers or ASNs observed in this campaign. Additionally, no malware families have been corroborated by abuse.ch, and no indicators have been flagged with high confidence by AbuseIPDB.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1213.002 Sharepoint
- T1539 Steal Web Session Cookie
- T1497.001 System Checks
- T1566.002 Spearphishing Link
- T1119 Automated Collection
- T1090 Proxy
- T1102 Web Service
- T1583.006 Web Services
- T1528 Steal Application Access Token
- T1098.001 Additional Cloud Credentials
- T1566 Phishing
- T1531 Account Access Removal
- T1027 Obfuscated Files or Information
- T1114.002 Remote Email Collection
- T1567.002 Exfiltration to Cloud Storage
- T1562.008 Impair Defenses: Disable or Modify Cloud Logs
- T1213 Data from Information Repositories
- T1071.001 Web Protocols
- T1550.001 Application Access Token
- T1078.004 Cloud Accounts

Analytical Scores

- Priority technique (graph chokepoint): T1566 Phishing (centrality 0.3037).
- Operational risk: Critical (score 1.0, reaches impact).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4062; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
POLONIUM	0.4062
HAFNIUM	0.379
FIN4	0.3443
APT28	0.3389
Confucius	0.3273

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Domain	dashboard-bl[.]pamconj[.]com
Domain	spx[.]pamconj[.]com

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1566 Phishing (initial-access)

- **Observed here:** the threat actor used T1078.004 Cloud Accounts here as an alternative initial-access technique.
- **Projected pivot:** T1078.004 Cloud Accounts (initial-access)
- **Basis:** observed in this campaign (an alternative the actor already demonstrated).

The actor could pivot to T1078.004 Cloud Accounts to maintain access and achieve their objectives by potentially exploiting weak cloud account credentials or authentication mechanisms, which may allow them to bypass the blocked phishing control. This technique could be used to target cloud-based services, which would likely provide the actor with an alternative means to gather sensitive information or disrupt operations. The defensive countermeasure to mitigate this potential pivot would be to Enforce MFA on all accounts; disable dormant and over-privileged accounts; alert on impossible-travel and anomalous logons.

Detection and hardening for the pivot (T1078.004 Valid Accounts)

- **Telemetry:** Windows Security (logon events); Azure AD / IdP sign-in logs; VPN and remote-access logs; Proxy / DLP / data-egress volume telemetry
- **Detect:**
 - Security 4624/4625 (logon success/fail), 4768/4769 (Kerberos TGT/TGS), 4776 (NTLM)
 - Impossible-travel, new-geo, and off-hours sign-ins from the IdP
 - Service or dormant accounts logging on interactively
 - Under valid credentials the identity signal goes quiet: baseline per-account data-egress volume and alert on peer-group and historical deviation (the real exfiltration tell)
- **Harden:**
 - Enforce MFA everywhere; disable stale accounts; rotate exposed credentials
 - Least-privilege review; separate admin from daily-driver accounts
 - Set per-account and per-partner egress baselines with DLP thresholds on sensitive stores
- **MITRE:** M1032 Multi-factor Authentication, M1026 Privileged Account Management, M1027 Password Policies, M1018 User Account Management · DS0028 Logon Session, DS0002 User Account